

INFORME DE INCIDENTE DE SEGURIDAD INFORMÁTICA

Basado en: SIEM-Log-Monitoring-Threat-Detection (laboratorio propio)

1. Datos generales

ID de incidente	INC-LAB-001
Fecha de detección	04/08/2026
Reportado por	Martin Alberto Benites Marin
Herramienta de detección	Wazuh SIEM + Sysmon (endpoint Windows 10)
Severidad	Media (CVSS v4.0: 6.9)
Estado	Cerrado — Simulación controlada en entorno de laboratorio

2. Resumen del incidente

Se detectó un ataque de fuerza bruta contra el protocolo SMB2 dirigido al endpoint Windows-Víctima (10.0.2.15), originado desde la máquina atacante Kali Linux (10.0.2.4) mediante la herramienta Hydra. El ataque generó múltiples eventos de autenticación fallida, capturados por el visor de eventos de seguridad de Windows e ingeridos por el agente de Wazuh instalado en el endpoint.

3. Indicadores de compromiso (IoC)

IP origen (atacante)	10.0.2.4 (Kali Linux)
IP/host destino (víctima)	10.0.2.15 (Windows 10 Enterprise)
Vector de ataque	Fuerza bruta vía SMB2 con Hydra
Evento de Windows	Event ID 4625 (fallo de autenticación)
Regla de Wazuh disparada	Rule ID 60122
Táctica / Técnica MITRE ATT&CK	Credential Access — T1110 (Brute Force)

4. Análisis

La correlación de múltiples eventos 4625 en un intervalo corto de tiempo, provenientes de una única IP externa (10.0.2.4) contra el mismo host objetivo, descarta un error de autenticación legítimo (como una contraseña mal escrita por un usuario) y confirma un patrón automatizado característico de un ataque de fuerza bruta. La regla 60122 de Wazuh está diseñada específicamente para correlacionar este volumen de intentos fallidos y elevar la alerta.

CVSS v4.0 Score: 6.9 Medium AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Exploitability Metrics

- Vector de Ataque (AV): Network (El protocolo SMB2 opera sobre TCP (puerto 445) y es alcanzable a nivel de red IP desde cualquier ubicación, sin requerir proximidad de capa de enlace)
- Complejidad del Ataque (AC): Low (Se uso una herramienta automatizada, sin necesidad de acceso previo)
- Requisitos de Ataque (AT): None (No se requieren condiciones previas del entorno o de la red para lanzar las peticiones con Hydra)
- Privilegios Requeridos (PR): None (El atacante no necesita autenticarse previamente en el sistema para enviar los intentos de login)
- Interacción del Usuario (UI): None (El ataque de fuerza bruta se ejecuta automáticamente vía red sin que un usuario en la máquina víctima tenga que hacer clic o interactuar)

Vulnerable System Impact Metrics

- Confidencialidad (VC): Low (Un ataque de fuerza bruta por sí solo no garantiza el acceso inmediato a todos los datos, pero si una clave débil es descubierta, compromete la confidencialidad de la cuenta afectada, pero en este caso no se descubrió ninguna)
- Integridad (VI): None (Los intentos fallidos de autenticación no modifican ni alteran datos en el sistema)
- Disponibilidad (VA): None (A menos que la ráfaga sea tan masiva que sature el ancho de banda (DoS), los intentos de inicio de sesión no botan el servicio SMB)

Subsequent System Impact Metrics

- Confidencialidad (SC): None (Los intentos de autenticación en la máquina local no impactan directamente sistemas externos o adyacentes)
- Integridad (SI): None (No hay alteración de integridad en otros sistemas)
- Disponibilidad (SA): None (No afecta la disponibilidad de otros sistemas)

Importante: Si la contraseña es adivinada con éxito, el impacto real escalaría inmediatamente a Critical (9.3 / VC:H/VI:H/VA:H) debido a que la cuenta Administrator por lo general permite ejecución remota de código.

5. Acciones tomadas / recomendadas

- Implementar política de bloqueo de cuenta (Account Lockout Threshold) tras 3-5 intentos fallidos.
- Restringir el tráfico de los puertos 445 (SMB) y 3389 (RDP) mediante firewall, permitiendo acceso solo desde subredes de administración autorizadas.
- Habilitar autenticación multifactor (MFA) en el endpoint.
- Mantener activa la regla 60122 de Wazuh para alertas tempranas ante futuros intentos similares.

6. Segundo hallazgo relevante del laboratorio (contexto adicional)

De forma complementaria, el mismo laboratorio permitió detectar la ejecución de un comando de PowerShell ofuscado en Base64 (uso del parámetro -EncodedCommand), capturado por Sysmon (Event ID 1) y correlacionado por la Regla 92057 de Wazuh, con severidad crítica (nivel 12). Esto corresponde a la táctica de Execution / Defense Evasion, técnica [T1059.001](#) de MITRE ATT&CK. Se recomienda habilitar Script Block Logging (una función de seguridad de Windows integrada en PowerShell que registra el contenido completo de cualquier código o comando que el motor procesa y ejecuta, guardándolo en el Visor de eventos de Windows bajo el ID de evento 4104) y restringir PowerShell mediante AppLocker o WDAC en modo Constrained Language Mode (función de seguridad de PowerShell en Windows que limita el uso de comandos avanzados, bloques de código complejos y llamadas directas a las API del sistema o de .NET, reduciendo así el riesgo de ataques informáticos).

7. Lecciones aprendidas

El laboratorio demostró la importancia de correlacionar eventos de múltiples fuentes (Windows Security Log + Sysmon) para obtener visibilidad completa de un ataque, y validó que reglas de detección personalizadas y bien afinadas (local_rules.xml) permiten distinguir con mayor precisión entre actividad legítima y maliciosa, reduciendo falsos positivos.

8. Conclusión

Incidente correspondiente a una simulación controlada dentro de un laboratorio propio de práctica. Ambos vectores de ataque fueron detectados exitosamente por el stack de Wazuh + Sysmon, validando la capacidad de ingesta, correlación y alerta del entorno SOC configurado.